

SabiID: Proving a Fact Without Revealing the Whole Record

ICSC 2026 Universities Hackathon. Track B, Digital Identity, Trust and ICT. Team Zer0Day Saints.

The problem

A shop that sells alcohol needs to know one thing about a customer: is this person over 18. A bank opening an account needs to know that the name on the form belongs to a verified identity, and that the person in front of the clerk is that person.

In both cases the question is small and the answer is a yes or a no. What actually changes hands is a whole identity document. It gets photographed, saved to a phone, copied into a spreadsheet, and forwarded by email. Every one of those copies is a place a date of birth, an address and a NIN can leak from later, and those leaks are what feed SIM swaps and account takeovers months afterward.

The same gap has an expensive public-sector version. Federal and state payrolls in Nigeria carry ghost workers and ghost pensioners: people who have died, retired without being removed, or never existed, kept on the books by whoever collects the payment. This happens because once a name is on the payroll, nobody asks again whether there is still a living, matching person behind it before the next payment goes out.

Both problems are the same problem. Somebody needs a fact confirmed, and the only tool on hand is the entire record.

What we built

In one sentence: SabiID is a broker that sits between the identity sources and the services that check identity, answers one narrow question at a time, signs the answer, and writes a line to a tamper-evident log, without ever copying anyone's record.

We deliberately did not build the national gateway our team pitched elsewhere, with its microservices and its multi-year rollout. For three weeks we carved out the one slice that is a working prototype and built that properly:

1. **A mock identity federation.** Three JSON stores stand in for the real sources: NIMC for the NIN record, NIBSS for the BVN record, and the Civil Registration service for deaths. SabiID never copies them. It reads the answer it needs at the moment it needs it and forgets the record. There is no master database in the design, so there is no single file to steal.
2. **Scoped questions with per-field consent.** A partner sends a request naming one citizen and a short list of predicates, for example `age_over_18`, `name_matches:Adaeze Chioma Nwosu`, `is_verified`. The citizen sees the exact list on their own device and approves it field by field. Anything not ticked comes back as `withheld`.
3. **Signed attestations.** The gateway holds one Ed25519 key pair. When it answers, it signs a small statement (the SID, the predicate, the result, an issue time, a fifteen minute expiry, a nonce). A partner verifies that signature against the gateway's published public key on its own server, with no call back to us. A stolen attestation expires within fifteen minutes and cannot be widened to anything the citizen did not approve. In the demo the partner console verifies the signature in the browser using WebCrypto, to show the

check needs nothing from us.

4. **Selective disclosure for the few cases that need a real value.** At enrolment the gateway issues an SD-JWT style credential. Its signed body carries only salted SHA-256 hashes of each claim. The plain values live only in the citizen's wallet. When a hospital genuinely needs a name to write on a chart, the response carries that one value plus a proof that its hash was in the signed credential. Nothing else about the record is disclosed. This is the lower-risk route the brief describes; a real zk-SNARK age proof is the natural next step and would slot in behind the same predicate interface.

5. **A living-person check that never moves a biometric.** At enrolment a face or fingerprint sample is hashed with scrypt and only the hash is kept. A later check hashes a fresh sample and compares. The raw biometric is never stored and never transmitted, so a breach of our database does not hand anyone a face.

6. **A proof-of-check log.** Every question is one line, and every line carries the SHA-256 hash of the line before it. Edit or delete a past line and every hash after it stops matching, and the break points at the line that moved. By construction a line holds a pseudonymous SID, the partner id, the names of the fields asked, the yes or no outcomes, and hashes. It never holds a date of birth, an address or a biometric.

The whole backend is Python from the standard library with one dependency, `cryptography`, for the Ed25519 signatures. Routing, storage (SQLite), hashing and JSON are all stock. It runs on a laptop with nothing installed.

The centrepiece: ghost workers and ghost pensioners

The payroll case reuses the identical mechanism, asked on a schedule instead of once. Before a ministry pays, SabilID sends each roster line the same kind of scoped request: is this still the same living person we enrolled as employee number X. The person answers with a fresh sample on their phone. The gateway returns a plain yes or no. No raw biometric moves and no new record is created. If the answer is no, or nobody answers, that one line is held for manual review, and the log entry becomes the documented reason the money was stopped. The audit log stops being a passive privacy record and starts doing a job for a payroll auditor. Our synthetic ministry has twelve lines. Seven are real active staff who answer correctly and are paid. Five are held back: one whose NIN is not in NIMC at all (a line that was never a person), one the Civil Registration service lists as deceased (caught before we even wait for a phone), one who has relocated and stops answering, one where the sample offered does not match the enrolment hash (a wrong person holding the phone), and one real staff member who was simply out of network signal this cycle. On this run the system pays 1,379,500 naira and holds back 955,000 naira across those five lines.

Why a business would choose this over demanding the ID

A business can always insist on the full ID, so the design has to be the easier option, not just the more private one. Three reasons it is. First, liability. When a partner leaks a customer's details, the business that collected them carries the blame. A business that holds no copy has nothing to leak and nothing to secure. Second, evidence. A signed, timestamped attestation that a check happened is

stronger proof for a regulator than a photocopy in a drawer, and the proof-of-check log is the business's own audit defence. Third, speed. There is no form to re-key and no document to file. The answer comes back in the time it takes the citizen to approve it. The privacy is real, but the reason a shop owner adopts it is that it is less work and less risk.

Results, honestly

What works. The consent flow returns only approved fields and nothing else; we tested that a date of birth never appears anywhere in a response even when age is answered. Every attestation the gateway issues verifies against its public key, and a flipped result or an expired attestation is rejected. The SD-JWT check rejects a claim value that was not in the signed credential. Editing a past log line is caught at that line; deleting a middle line is caught as a gap. The biometric hash never contains the sample. The ghost sweep catches all four planted ghosts. All of this is covered by 34 assertions in `tests/run_tests.py`, which run with no framework.

Where it fails, and we can show each one.

- **Name matching is exact after normalising case and spacing.** A reversed name order (Chukwuemeka Alfred Okafor against Alfred Chukwuemeka Okafor) or a dropped accent reads as a mismatch for the same person. We left three such people in the synthetic data. This is the honest cost of not returning the name: we cannot do a fuzzy human review of a value we refuse to disclose.
- **The living-person check has a real cost.** A staff member out of signal looks exactly like a ghost at the moment of the check. The system does not guess, it routes them to a human. In our seeded data that is one line in twelve. In salary mode a grace window of three missed cycles softens this; in pension mode there is no grace and the false hold happens on the first miss.
- **A stolen enrolment sample would defeat the liveness check.** Our stand-in for a biometric is a string. A real deployment needs a device-attested capture and a per-check challenge so a replayed sample is rejected. We hash and salt the enrolment sample so a database breach alone does not yield it, but we do not claim presentation-attack resistance.
- **A pure hash chain cannot see its own tail being cut off.** If the last few lines are deleted, the shorter chain still verifies. We added a `head` value an auditor notes out of band, and check against it, but the clean fix is to publish the latest head hash somewhere external on a schedule.
- **The confidence score is a heuristic, not a calibrated probability.** It starts at 0.99 and subtracts fixed amounts when only one identifier matched, when the NIN and BVN names disagree, when a date of birth differs between sources, and so on. It is a rough ordering aid for a human, and the write-up says so on the screen next to the number.
- **The OTP is simulated.** Any six digits stand in for a real SIM OTP or a device prompt. The consent mechanic is real; the second factor is a placeholder.

Synthetic data. Everything is generated by `backend/data_gen.py` with a fixed seed. Names are common Nigerian given names and surnames combined at random. NIN and BVN numbers are random digits with a deliberately non-real prefix. Dates of

birth, states and phone numbers are random. The deliberate inconsistencies (name order, a dropped accent, a one-year typo, a NIN-only record) and the ghost lines are placed by index and documented in `data/DATA_CARD.md`. No real person's data is used anywhere.

Power and network cuts. These are normal here, so we built for them. If the sources are unreachable, a payroll cycle does not pay anyone. Every line is queued, and a reconcile step replays the queue once the link is back. The log records the outage and the reconcile as their own lines, and the chain still verifies across the gap. The USSD path covers the citizen with a basic phone and weak signal: the same approvals over a short code, with the face check skipped and the citizen told it was skipped.

Beyond the prototype

The parts we did not build, and would build next, are: a real second factor and a device-attested biometric capture; a zk-SNARK age proof behind the existing predicate interface; a published-checkpoint scheme for the log; and a fuzzy, human-in-the-loop name review path that stays inside the consent model. The national rollout, the partner onboarding and the cross-border pieces from our wider pitch are a product, not a three-week prototype, and we have kept them out of this submission on purpose.

Running it and the code

```
python3 -m backend.data_gen      # generate synthetic data, seed the database
python3 -m backend.app           # serve on http://127.0.0.1:8099
python3 tests/run_tests.py       # 34 assertions, no framework
```

The recorded walkthrough is `demo/out/demo.mp4` with section timecodes in `demo/out/sections.json`. Code: <add your repository link here>.